

SOC Triage & Incident Response Playbook 2026

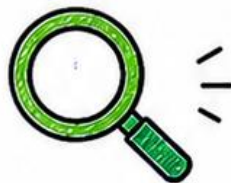
Application-Driven Security Incidents | SOC L1 → L2 → L3 Workflow

L1 TRIAGE



- Validate Alert
- Check Context
- Prioritize

L2 INVESTIGATION



- Correlate Logs
- Identify Scope
- Escalate

L3 RESPONSE



- Contain
- Recover
- Review

ALERT → TRIAGE → INVESTIGATE → RESPOND



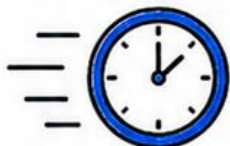
.....



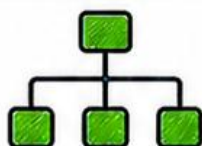
.....



WHY IT MATTERS



Faster Detection



Clear Escalation



Stronger Response

Why this playbook exists

In modern environments, attackers rarely break in. They login. They:

- Reuse leaked credentials
- Abuse weak authentication
- Bypass MFA through fatigue or logic gaps
- Use valid accounts to avoid detection

This is why SOC teams now investigate login behaviour, not just malware. This playbook addresses behavioural abuse of authentication mechanisms.

Playbook Metadata

Item	Details
Playbook ID	SOC-APP-01
Incident Category	Application-Driven Account Compromise
Primary Focus	Login Behavior
SOC Coverage	L1 → L2 → L3
Framework References	OWASP, MITRE ATT&CK, NIST SP 800-61
2026 Relevance	Critical (Cloud, SaaS, API, IAM-centric world)

1. What is “Abnormal Login Behaviour”?

Abnormal login behaviour is any authentication activity that deviates from a user’s normal pattern, even if credentials are valid.

This includes:

- Too many failed logins
- Successful login after repeated failures
- Login from unusual country or ASN
- Login outside normal hours
- Login without expected MFA challenge
- Sudden device or browser change

Key principle: Valid credentials ≠ legitimate access

2. Alert Triggers (What SOC Actually Sees)

Alert Source	Trigger Example	Why It Matters
SIEM	10 failed logins → 1 success	Credential stuffing indicator
IAM	Login from new country	Possible account takeover

Alert Source	Trigger Example	Why It Matters
UEBA	Behaviour risk score spike	Identity misuse
Application Logs	New session after auth errors	Logic abuse
Cloud IDP	MFA challenge skipped	Control failure

3. Initial Triage – L1 SOC (Decision Gate)

Objective: Decide if this is noise, suspicious, or malicious.

Triage Question	Yes	No	Why This Matters
Is the account valid and active?	Continue	Close	Remove false alerts
Failed logins before success?	Continue	Note	Brute force pattern
New geo / ASN / VPN?	Continue	Note	Stolen credentials
Unusual login time?	Continue	Note	UEBA signal
MFA enforced?	Continue	Escalate	Control weakness
Privileged account?	Escalate	Continue	Blast radius

L1 Rule (2026): Behavioural deviation = investigate, even without malware

4. Context Enrichment – L1 → L2

SOC must enrich before judging.

Context Dimension	What to Check	Explanation
Geography	Country, ASN, TOR/VPN	Detect credential resale usage
Device	Browser, OS, fingerprint	Identify session hijack
Time	Working hours vs off-hours	Anomaly confirmation
Account Role	Admin / Finance / API	Impact assessment
Auth Method	Password, SSO, MFA	Control strength
Session Behaviour	Idle vs active	Attacker dwell time

5. Threat Classification (Standardised)

Category	Mapping
OWASP	Broken Authentication
MITRE ATT&CK	Credential Access → Initial Access

Category	Mapping
Attack Type	Credential Stuffing / Password Reuse
Incident Type	Account Compromise (Suspected / Confirmed)

Why this matters: Classification ensures:

- Consistent reporting
- Repeatable response
- Audit defensibility

6. Severity Assessment (Risk-Based, Not Feel-Based)

Factor	Low	Medium	High
Account Type	Normal user	Power user	Admin / Finance
MFA Status	Strong	Weak	Absent / Bypassed
Behaviour	Minor deviation	Clear anomaly	Active misuse
Data Access	None	Limited	Sensitive / PII

Severity Logic: Privilege × Behaviour × Data Exposure

7. Containment – L2 SOC (Immediate Controls)

Action	Owner	Reason
Force password reset	SOC / IAM	Kill attacker access
Revoke all sessions	SOC	Stop live misuse
Revoke API tokens	SOC	Prevent automation abuse
Block IP / ASN	SOC	Slow attacker
Enforce MFA	IAM	Structural control

Important: Containment must happen even if investigation is ongoing.

8. Evidence Preservation (Before Eradication)

Evidence	Source	Purpose
Auth logs	IAM / App	Timeline reconstruction
Session logs	App / Proxy	Attacker actions
UEBA scores	SIEM	Behaviour proof
IP intelligence	CTI	Attribution support

Rule: Never fix first, investigate later.

G. Eradication – L2 → L3

Step	Why
Credential reset	Remove attacker foothold
Access review	Reduce privilege abuse
MFA policy hardening	Prevent repeat
Login logic review	Close app-level gaps

10. Recovery & Monitoring

Step	Validation
User identity verified	Business confirmation
New clean session	No reuse
API usage baseline	Normalised
Monitoring window	24–48 hours

11. Post-Incident Review (Mandatory in 2026)

Review Area	Question
Root Cause	Credential reuse? MFA gap?
Detection	Early enough?
Control Gap	Preventable?
Improvement	SIEM rule, MFA policy
Training	User / SOC

12. Management-Ready Incident Summary

Item	Example
Incident	Abnormal login detected
Impact	No data loss
Detection	Behaviour-based correlation
Containment	<15 minutes
Improvement	MFA enforced

PLAYBOOK 2 – ABNORMAL API USAGE PATTERNS (APPLICATION-DRIVEN)

Why this playbook exists

In 2026, APIs are the primary attack surface. Attackers no longer need to:

- Exploit vulnerabilities
- Drop malware
- Gain shell access

They simply abuse APIs exactly as designed, but at:

- Abnormal speed
- Abnormal volume
- Abnormal scope

This is why SOC teams now investigate API usage patterns, not just API failures.

Playbook Metadata

Item	Details
Playbook ID	SOC-APP-02
Incident Category	Application-Driven Abuse
Primary Focus	API Usage Behaviour
SOC Coverage	L1 → L2 → L3
Framework References	OWASP, MITRE ATT&CK, NIST SP 800-61
2026 Relevance	Critical (API-first, SaaS, FinTech, GovTech)

1. What is “Abnormal API Usage”?

Abnormal API usage occurs when an API is used:

- By a valid token
- From a legitimate endpoint
- But in a way no normal user or system would behave This includes:
 - Excessive request rates
 - Large-scale data enumeration
 - Accessing objects not owned by the user
 - Automated scraping
 - Token reuse from new geographies

principle: Valid token ≠ legitimate intent

2. Common SOC Alert Triggers

Alert Source	Trigger Example	Why It Matters
API Gateway	Rate limit exceeded	Automation / scraping
SIEM	10,000 requests in minutes	Enumeration
UEBA	Token behaviour anomaly	Token misuse
App Logs	Sequential object IDs	Broken access control
Cloud IAM	Token used from new ASN	Token theft

3. Initial Triage – L1 SOC (Decision Gate)

Objective: Decide if API behaviour is normal, misconfigured, or malicious.

Triage Question	Yes	No	Explanation
Is API publicly exposed?	Continue	Note	Exposure context
Is token valid?	Continue	Escalate	Possible forgery
Request volume abnormal?	Continue	Note	Automation
Object IDs sequential?	Continue	Escalate	Enumeration
Geo / ASN change?	Continue	Note	Token leakage
Business API?	Escalate	Continue	High impact

L1 Rule: Rate + pattern > payload

4. Context Enrichment – L1 → L2

Context Dimension	What to Check	Why
API Endpoint	/users, /transactions	Sensitivity
HTTP Method	GET vs POST	Read vs modify
Request Pattern	Sequential / random	Enumeration
Token Scope	Read-only / admin	Impact
Client Type	Mobile / backend	Abuse detection
Time Pattern	Burst vs steady	Automation

5. Threat Classification

Category	Mapping
OWASP	API Broken Object Level Authorization (BOLA)

Category	Mapping
MITRE ATTCK	Collection → Exfiltration
Attack Type	API Scraping / Enumeration
Incident Type	Data Exposure (Suspected / Confirmed)

Why this matters: API abuse often looks “successful” because the API returns 200 OK.

6. Severity Assessment (API-Specific)

Factor	Low	Medium	High
Endpoint Sensitivity	Public data	User data	PII / Financial
Token Privilege	Limited	Broad	Admin
Volume	Slight spike	Sustained abuse	Massive
Data Returned	Minimal	Partial	Full datasets

Severity Logic: Endpoint Sensitivity × Token Scope × Volume

7. Containment – L2 SOC

Action	Owner	Reason
Revoke API token	SOC	Stop abuse
Apply rate limit	API Gateway	Control automation
Block IP / ASN	SOC	Slow attacker
Temporarily disable endpoint	App Team	Stop data loss
Force token rotation	IAM	Kill leaked tokens

Important: API incidents escalate faster than login incidents due to silent data loss.

8. Evidence Preservation

Evidence	Source	Purpose
API access logs	Gateway	Request timeline
Token usage logs	IAM	Token misuse
Response size logs	SIEM	Data exposure
IP reputation	CTI	Threat context

Rule: Preserve request–response metadata before revocation.

G. Eradication – L2 → L3

Step	Purpose
Rotate all related tokens	Kill persistence
Fix authorization logic	Prevent BOLA
Enforce rate limiting	Prevent scraping
Add behaviour-based alerts	Early detection

10. Recovery & Monitoring

Step	Validation
API restored	After fixes
Token reissued	Least privilege
Usage baseline	Normalised
Monitoring	48–72 hours

11. Post-Incident Review

Area	Key Question
Root Cause	Logic gap? Rate limit absence?
Detection Delay	Could it be earlier?
Control Failure	Design vs config
Improvement	New SIEM rule
Dev Action	Code-level fix

12. Management-Ready Summary

Item	Example
Incident	Abnormal API usage detected
Impact	Partial data exposure
Detection	Behaviour-based correlation
Containment	<10 minutes
Preventive Action	Token scope + rate limit

PLAYBOOK 3 – BUSINESS LOGIC MISUSE (APPLICATION-DRIVEN)

Why this playbook exists

In modern applications, attackers often don't exploit vulnerabilities. They exploit rules.

They:

- Chain legitimate features in unintended ways
 - Abuse workflows that were never designed for hostile users
 - Perform actions in a sequence that developers never anticipated
- This is why SOC teams investigate business logic misuse because:
- Requests are valid
 - Responses are successful
 - No errors are thrown
 - No malware is present

Key reality (2026): If you only look for failures, you will miss successful abuse.

Playbook Metadata

Item	Details
Playbook ID	SOC-APP-03
Incident Category	Application Logic Abuse
Primary Focus	Business Logic Misuse
SOC Coverage	L1 → L2 → L3
Framework References	OWASP, MITRE ATT&CK, NIST SP 800-61
2026 Relevance	Critical (FinTech, GovTech, e-Commerce, SaaS)

1. What is Business Logic Misuse?

Business logic misuse occurs when an attacker uses application features exactly as designed, but:

- In the wrong order
- At abnormal scale
- Without intended constraints
- To gain unfair advantage, data, or money

Examples:

- Reusing coupons repeatedly
- Bypassing payment steps
- Mass-creating accounts for abuse
- Automating refund workflows
- Chaining APIs to extract data indirectly

Key principle: Security controls can be perfect, but logic can still be abused.

2. Typical SOC Alert Triggers

Alert Source	Trigger Example	Why It Matters
SIEM	Repeated successful transactions	Abuse at scale
UEBA	User behaviour deviates sharply	Automation
App Logs	Same workflow repeated rapidly	Logic abuse
Fraud Engine	Transaction pattern anomaly	Financial impact
API Logs	Valid calls in abnormal sequence	Workflow chaining

3. Initial Triage – L1 SOC (Decision Gate)

Objective: Decide if behaviour is normal heavy usage or intentional abuse.

Triage Question	Yes	No	Explanation
Requests technically valid?	Continue	Escalate	No exploit needed
Same workflow repeated?	Continue	Note	Automation
High success rate?	Continue	Note	Silent abuse
Business impact visible?	Escalate	Continue	Risk signal
User human-like?	Continue	Escalate	Bot behaviour
Financial/ data effect?	Escalate	Continue	Severity

L1 Rule: Repetition + success + scale = investigate

4. Context Enrichment – L1 → L2

Context Dimension	What to Check	Why
Workflow	Signup, checkout, refund	Abuse surface
Sequence	Step order correctness	Logic gap

Context Dimension	What to Check	Why
Rate	Human vs automated	Bot detection
Account Age	New vs established	Abuse profile
Incentives	Coupons, credits, points	Motivation
Geography	Normal vs proxy	Fraud indicator

5. Threat Classification

Category	Mapping
OWASP	Business Logic Vulnerabilities
MITRE ATTCK	Impact → Collection
Attack Type	Logic Abuse / Fraud
Incident Type	Business Abuse (Confirmed / Suspected)

Important: OWASP explicitly states business logic issues cannot be detected by scanners SOC detection is essential.

6. Severity Assessment (Impact-Driven)

Factor	Low	Medium	High
Business Impact	None	Minor	Financial / Data
Automation	Low	Moderate	High
Abuse Duration	Short	Sustained	Long-term
Detection Difficulty	Easy	Moderate	Hard

Severity Logic: Business Impact × Automation × Duration

7. Containment – L2 SOC (Fast but Careful)

Action	Owner	Reason
Temporarily suspend account	SOC	Stop abuse
Rate-limit workflow	App / Gateway	Slow automation
Disable incentives	Business / App	Stop loss
Block bot IP / ASN	SOC	Reduce scale
Add behavioural rules	SOC	Early detection

Warning: Do not over-block legitimate users without business validation.

8. Evidence Preservation

Evidence	Source	Purpose
Workflow logs	Application	Sequence proof
Transaction logs	Backend	Impact calculation
Behaviour profiles	UEBA	Automation
API call chains	SIEM	Abuse pattern

Rule: Capture sequences, not single even

G. Eradication – L2 → L3

Step	Purpose
Fix logic gap	Prevent recurrence
Add server-side validation	Enforce rules
Add abuse thresholds	Detect early
Improve alert correlation	SOC maturity

10. Recovery & Monitoring

Step	Validation
Legit users restored	Business approval
Incentives reset	Finance sign-off
Normal behaviour baseline	SIEM
Monitoring window	7–14 days

11. Post-Incident Review (Critical)

Area	Key Question
Root Cause	Design flaw? Missing checks?
Detection	Behaviour-based enough?
Business Loss	Quantified?
Improvement	Logic + SOC rules
Awareness	Dev C Product training

12. Management-Ready Summary

Item	Example
Incident	Business logic misuse detected
Impact	Financial loss prevented
Detection	Behaviour C sequence analysis
Containment	<30 minutes
Preventive Action	Workflow hardening

PLAYBOOK 4 – ACCESS CONTROL FAILURES (APPLICATION-DRIVEN)

Why this playbook exists

Access control answers one question:

“Is this user allowed to do this?” In modern attacks:

- Authentication works
- Requests are valid
- Tokens are legitimate
- Applications respond successfully Yet attackers access:
 - Other users’ data
 - Admin functions
 - Restricted objects
 - Internal APIs

This is why SOC teams investigate access control failures, not just failed logins.

Playbook Metadata

Item	Details
Playbook ID	SOC-APP-04
Incident Category	Authorization Failure
Primary Focus	Access Control
SOC Coverage	L1 → L2 → L3
Framework References	OWASP, MITRE ATTCK, NIST SP 800-61
2026 Relevance	Critical (API-first, microservices, RBAC/ABAC)

1. What is an Access Control Failure?

An access control failure occurs when:

- A user is authenticated
- A request is valid
- But the application fails to enforce authorisation. This allows actions such as:
 - Viewing other users' records (IDOR)
 - Modifying objects not owned by the user
 - Accessing admin endpoints
 - Performing actions beyond assigned roles

Key principle: Authentication proves who you are. Authorisation decides what you can do.

2. Typical SOC Alert Triggers

Alert Source	Trigger Example	Why It Matters
Application Logs	User accesses foreign object ID	IDOR
API Logs	200 OK on restricted endpoint	Silent failure
SIEM	Multiple object IDs accessed	Enumeration
UEBA	Privilege usage anomaly	Role abuse
WAF	Parameter tampering	Authorization bypass

3. Initial Triage – L1 SOC (Decision Gate)

Objective: Determine if access was legitimate, misconfigured, or malicious.

Triage Question	Yes	No	Explanation
Is user authenticated?	Continue	Escalate	Bypass attempt
Is object owned by user?	Escalate	Continue	IDOR
Is endpoint restricted?	Escalate	Continue	Privilege abuse
Are responses successful?	Continue	Note	Silent exploit
Repeated access?	Escalate	Continue	Enumeration
Business-critical data?	Escalate	Continue	Severity

L1 Rule: Successful response to forbidden action = incident

4. Context Enrichment – L1 → L2

Context Dimension	What to Check	Why
User Role	User / Admin	Privilege
Object Ownership	User ID vs object ID	IDOR
Endpoint Type	Internal / Admin	Sensitivity
Request Pattern	Sequential IDs	Enumeration
Token Scope	Limited vs broad	Mis-scope
Source	Internal vs external	Exposure

5. Threat Classification

Category	Mapping
OWASP	Broken Access Control
MITRE ATTCK	Privilege Escalation / Collection
Attack Type	IDOR / Authorization Bypass
Incident Type	Unauthorized Access

Why this matters: Broken access control has ranked #1 in OWASP Top 10 because it causes direct data exposure.

6. Severity Assessment (Data-Centric)

Factor	Low	Medium	High
Data Type	Non-sensitive	Internal	PII / Financial
Scope	Single object	Multiple	Mass
Privilege Gap	Minor	Moderate	Admin-level
Abuse Pattern	Accidental	Targeted	Systematic

Severity Logic: Data Sensitivity × Scope × Privilege Gap

7. Containment – L2 SOC

Action	Owner	Reason
Revoke session/token	SOC	Stop access
Block endpoint	App / Gateway	Stop data leak
Apply WAF rule	SOC	Immediate protection
Suspend account	SOC	Prevent escalation
Notify app owner	SOC	Business coordination

Priority: Contain before attacker enumerates further objects.

8. Evidence Preservation

Evidence	Source	Purpose
Access logs	Application	Proof of unauthorized access
Object IDs	Backend	Impact scope
API traces	Gateway	Sequence
SIEM timeline	SOC	Correlation

Rule: Preserve access paths, not just endpoints.

G. Eradication – L2 → L3

Step	Purpose
Fix authorization checks	Close gap
Enforce server-side validation	Prevent bypass
Apply least privilege	Reduce blast radius
Add access alerts	Early detection

10. Recovery G Monitoring

Step	Validation
Access restored (if false positive)	Business sign-off
Affected users notified	Compliance
Monitoring window	7 days
No further violations	SIEM

11. Post-Incident Review

Area	Key Question
Root Cause	Missing check? Design flaw?
Detection	Was it timely?
Impact	Data accessed?
Prevention	Design + SOC rules
Training	Dev C SOC

12. Management-Ready Summary

Item	Example
Incident	Unauthorized data access detected
Impact	Limited exposure
Detection	Behaviour-based access monitoring
Containment	<10 minutes
Preventive Action	Authorization fix

PLAYBOOK 5 – DATA ACCESS ANOMALIES (APPLICATION-DRIVEN)

Why this playbook exists

Most breaches are not discovered when access happens.

They are discovered when data moves abnormally.

In 2026:

- Attackers often already have access
- Credentials, tokens, or sessions are valid
- APIs and apps respond normally

The only remaining signal is how data is accessed, queried, or extracted.

This is why SOC teams investigate data access anomalies.

Playbook Metadata

Item	Details
Playbook ID	SOC-APP-05
Incident Category	Data Exposure / Exfiltration
Primary Focus	Data Access Behaviour
SOC Coverage	L1 → L2 → L3
Framework References	OWASP, MITRE ATT&CK, NIST SP 800-61
2026 Relevance	Critical (Data-centric security era)

1. What is a Data Access Anomaly?

A data access anomaly occurs when data is accessed in a way that deviates from normal behaviour, even though:

- The user is authenticated
- The request is authorised
- The application works as expected

Examples:

- Sudden bulk downloads
- Repeated queries across many records
- Accessing data outside normal role usage
- High-volume API responses
- Long-running export jobs

Key principle: Breaches are measured in data, not logins.

2. Typical SOC Alert Triggers

Alert Source	Trigger Example	Why It Matters
SIEM	Large response size spike	Data extraction
UEBA	User downloads far above baseline	Misuse
App Logs	Export function abused	Legit feature
Database Logs	Full table scans	Enumeration
Cloud Logs	Unusual S3 / Blob reads	Data exfil

3. Initial Triage – L1 SOC (Decision Gate)

Objective: Determine if data access is legitimate, excessive, or malicious.

Triage Question	Yes	No	Explanation
Is user authenticated?	Continue	Escalate	Access violation
Is access authorised?	Continue	Escalate	Control failure
Volume above baseline?	Continue	Note	Extraction
Repeated queries?	Continue	Note	Enumeration
Sensitive data involved?	Escalate	Continue	Severity
Business justification exists?	Continue	Escalate	Abuse

L1 Rule: Abnormal volume + sensitive data = investigate immediately

4. Context Enrichment – L1 → L2

Context Dimension	What to Check	Why
Data Type	PII, financial, internal	Impact
Access Method	UI, API, export	Abuse surface
Query Pattern	Sequential / wildcard	Enumeration

Context Dimension	What to Check	Why
Time	Off-hours access	Stealth
Role	Analyst vs admin	Expectation
Destination	Download, sync, export	Exfil risk

5. Threat Classification

Category	Mapping
OWASP	Excessive Data Exposure
MITRE ATTCK	Collection → Exfiltration
Attack Type	Data Harvesting
Incident Type	Data Breach (Suspected / Confirmed)

Important: Most data breaches happen after successful authentication.

6. Severity Assessment (Data-First)

Factor	Low	Medium	High
Data Sensitivity	Public	Internal	PII / Regulated
Volume	Small	Moderate	Large
Access Duration	Short	Sustained	Prolonged
Intent	Accidental	Suspicious	Malicious

Severity Logic: Data Sensitivity × Volume × Intent

7. Containment – L2 SOC (Time-Critical)

Action	Owner	Reason
Revoke session/token	SOC	Stop access
Pause exports	App / DB	Stop leakage
Disable API endpoint	App	Prevent extraction
Block destination IP	SOC	Exfil control
Suspend account	SOC	Insider / takeover

Priority: Containment speed > attribution accuracy.

8. Evidence Preservation

Evidence	Source	Purpose
----------	--------	---------

Evidence	Source	Purpose
Access logs	Application	Proof of access
Query logs	Database	Data scope
Export records	Backend	Volume
UEBA baseline	SIEM	Behaviour comparison
Cloud object logs	Storage	Exfil path

Rule: Capture what data was accessed, not just who.

G. Eradication – L2 → L3

Step	Purpose
Rotate credentials	Kill persistence
Reduce data exposure	Least privilege
Add access thresholds	Early detection
Mask sensitive fields	Limit impact

10. Recovery G Monitoring

Step	Validation
Legit access restored	Business sign-off
Data integrity verified	No tampering
Monitoring window	14–30 days
No recurrence	SIEM confirmation

11. Post-Incident Review (Mandatory)

Area	Key Question
Root Cause	Excessive access rights?
Detection	Too late or timely?
Data Impact	Quantified?
Compliance	Notification needed?
Improvement	Data-centric alerts

12. Management-Ready Summary

Item	Example
------	---------

Item	Example
Incident	Abnormal data access detected
Impact	No confirmed exfiltration
Detection	Behaviour C volume analysis
Containment	<5 minutes
Preventive Action	Access thresholds enforced

PLAYBOOK 6 – TOKEN, SESSION & OAUTH ABUSE (APPLICATION-DRIVEN)

Why this playbook exists

In 2026, attackers increasingly do not steal passwords.

They steal:

- Access tokens
- Refresh tokens
- OAuth grants
- Session cookies

Because:

- Tokens bypass MFA
- Tokens look legitimate
- Tokens are trusted by applications
- Token misuse produces no login failure

This is why SOC teams investigate token and session behaviour, not just authentication events.

Playbook Metadata

Item	Details
Playbook ID	SOC-APP-06
Incident Category	Identity C Session Abuse
Primary Focus	Token / OAuth / Session Misuse
SOC Coverage	L1 → L2 → L3
Framework References	OWASP, MITRE ATT&CK, NIST SP 800-61
2026 Relevance	Critical (SSO, SaaS, cloud-native, API-first)

1. What is Token / Session Abuse?

Token or session abuse occurs when an attacker:

- Uses a legitimate token or session
- Without performing a login
- Often from a different device, location, or context

Common token types abused:

- OAuth access tokens
- Refresh tokens
- API keys
- Session cookies
- Service account tokens

Key principle: If authentication is bypassed, detection must shift to usage behaviour.

2. Typical SOC Alert Triggers

Alert Source	Trigger Example	Why It Matters
IAM / IDP	Token used without recent login	Token replay
SIEM	Same token used from 2 geos	Token theft
UEBA	Session behaviour anomaly	Hijacked session
API Gateway	Long-lived token abuse	Persistence
Cloud Logs	OAuth app accessing unusual data	Consent abuse

3. Initial Triage – L1 SOC (Decision Gate)

Objective: Determine whether access is **normal delegated use** or **token misuse**.

Triage Question	Yes	No	Explanation
Token/session valid?	Continue	Escalate	Forgery risk
Login event exists?	Continue	Escalate	Silent access
Geo/device changed?	Continue	Note	Replay
Token scope broad?	Escalate	Continue	Impact
Long-lived token?	Continue	Note	Persistence
Sensitive API/data used?	Escalate	Continue	Severity

L1 Rule (2026): No login + active access = investigate immediately

4. Context Enrichment – L1 → L2

Context Dimension	What to Check	Why
Token Type	Access / refresh / API	Abuse capability
Token Age	Short vs long-lived	Persistence
Scope / Permission	Read vs admin	Blast radius
OAuth App	First-party / third-party	Consent abuse
Session Binding	IP / device bound?	Hijack risk
Usage Pattern	Human vs automated	Bot activity

5. Threat Classification

Category	Mapping
OWASP	Broken Authentication / Session Management
MITRE ATTCK	Credential Access → Persistence
Attack Type	Token Theft / Session Hijack
Incident Type	Identity Compromise

Important: OAuth abuse often appears as legitimate application activity.

6. Severity Assessment (Identity-Centric)

Factor	Low	Medium	High
Token Scope	Minimal	Broad	Admin
Data Access	None	Internal	PII / Financial
Persistence	Short	Sustained	Long-term
Detection Difficulty	Easy	Moderate	Hard

Severity Logic: Token Scope × Data Access × Persistence

7. Containment – L2 SOC (Immediate)

Action	Owner	Reason
Revoke token/session	SOC	Kill access
Revoke OAuth consent	IAM / App	Stop abuse
Rotate secrets	App / Cloud	Prevent reuse
Block suspicious IP/ASN	SOC	Slow attacker

Action	Owner	Reason
Disable OAuth app	App Owner	Prevent spread

Priority: Containment must be faster than session reuse.

8. Evidence Preservation

Evidence	Source	Purpose
Token issuance logs	IAM	Entrypoint
API usage logs	Gateway	Abuse scope
OAuth consent logs	IDP	Attribution
UEBA baselines	SIEM	Behaviour proof
Session timelines	App	Hijack pattern

Rule: Preserve token usage timelines before revocation.

G. Eradication – L2 → L3

Step	Purpose
Rotate all related tokens	Remove persistence
Enforce short token TTL	Limit exposure
Bind tokens to device/IP	Prevent replay
Restrict OAuth scopes	Least privilege

10. Recovery & Monitoring

Step	Validation
Legit sessions restored	Business confirmation
OAuth apps reviewed	Trust re-established
Monitoring window	14–30 days
No silent reuse	SIEM confirmation

11. Post-Incident Review

Area	Key Question
Root Cause	Token leak? Consent abuse?
Detection Gap	Too late?
Control Gap	Token lifetime too long?

Area	Key Question
Improvement	Behaviour-based rules
Awareness	DevC IAM teams

12. Management-Ready Summary

Item	Example
Incident	Token misuse detected
Impact	No confirmed data breach
Detection	Behavioural session analysis
Containment	<5 minutes
Preventive Action	Token hardening

PLAYBOOK 7 – INSIDER MISUSE & ABUSE OF LEGITIMATE ACCESS

Why this playbook exists

Not all threats come from outside. In 2026:

- Users work remotely
- Privileges are broad
- Data access is decentralised
- APIs and SaaS expose sensitive data
- Insider actions look legitimate Most insider incidents:
 - Use valid accounts
 - Follow authorised paths
 - Trigger no technical errors
 - Are discovered late

This is why SOC teams investigate insider behaviour, not just external attacks.

Playbook Metadata

Item	Details
Playbook ID	SOC-APP-07
Incident Category	Insider Threat
Primary Focus	Misuse of Legitimate Access

Item	Details
SOC Coverage	L1 → L2 → L3
Framework References	OWASP, MITRE ATT&CK, NIST SP 800-61
2026 Relevance	High (Remote work, data-centric abuse)

1. What is Insider Misuse?

Insider misuse occurs when a trusted user:

- Uses their access beyond business purpose
- Exploits knowledge of systems or workflows
- Gradually escalates data access
- Intentionally or negligently causes harm Types:
- Malicious insider (intentional)
- Negligent insider (careless)
- Compromised insider (account taken over)

Key principle: Legitimacy of access does not equal legitimacy of intent.

2. Typical SOC Alert Triggers

Alert Source	Trigger Example	Why It Matters
UEBA	Gradual increase in data access	Slow exfiltration
SIEM	Repeated off-hours activity	Stealth
App Logs	Accessing unrelated datasets	Curiosity abuse
Cloud Logs	Large exports by staff	Data theft
IAM	Privilege usage spike	Role abuse

3. Initial Triage – L1 SOC (Decision Gate)

Objective: Distinguish business need vs misuse without assumptions.

Triage Question	Yes	No	Explanation
User is authorised?	Continue	Escalate	Control failure
Behaviour deviates from baseline?	Continue	Note	UEBA
Access outside job role?	Escalate	Continue	Abuse
Off-hours / unusual timing?	Continue	Note	Stealth

Triage Question	Yes	No	Explanation
Data sensitivity high?	Escalate	Continue	Risk
Repeated pattern?	Escalate	Continue	Intent

L1 Rule: Repeated legitimate actions outside business context = investigate

4. Context Enrichment – L1 → L2

Context Dimension	What to Check	Why
Job Role	Expected access scope	Baseline
Department	Data relevance	Justification
Time Pattern	Work vs off-hours	Stealth
Access Method	UI / API / export	Intent
Volume Trend	Gradual vs burst	Insider profile
Peer Comparison	Similar role behaviour	Outlier detection

5. Threat Classification

Category	Mapping
OWASP	Excessive Data Exposure
MITRE ATT&CCK	Collection → Exfiltration
Attack Type	Insider Data Abuse
Incident Type	Insider Threat (Suspected / Confirmed)

Important: Insider threats often bypass perimeter and authentication controls entirely.

6. Severity Assessment (Intent-Aware)

Factor	Low	Medium	High
Data Sensitivity	Internal	Confidential	Regulated / PII
Volume	Small	Moderate	Large
Duration	Short	Sustained	Long-term
Intent Confidence	Unclear	Suspicious	Clear

Severity Logic: Data Sensitivity × Volume × Intent

7. Containment – L2 SOC (Careful G Controlled)

Action	Owner	Reason
Limit data access	IAM	Reduce exposure

Action	Owner	Reason
Revoke export permissions	App / IAM	Stop leakage
Monitor silently	SOC	Avoid tipping off
Suspend account (if confirmed)	HR / SOC	Prevent harm
Secure evidence	SOC	Legal readiness

Critical Rule: Do not alert the user prematurely unless risk is imminent.

8. Evidence Preservation (High Sensitivity)

Evidence	Source	Purpose
Access logs	Application	Proof of misuse
Export records	Backend	Impact
UEBA timeline	SIEM	Behaviour trend
Data scope list	App / DB	Breach assessment
Audit trails	IAM	Attribution

Rule: Insider cases require clean, defensible evidence.

G. Eradication – L2 → L3

Step	Purpose
Remove excessive privileges	Least privilege
Enforce separation of duties	Structural fix
Mask sensitive data	Limit future abuse
Improve UEBA thresholds	Early detection

10. Recovery & Monitoring

Step	Validation
Business operations unaffected	Management
Access revalidated	IAM
Monitoring window	30–90 days

Step	Validation
No recurrence	SIEM

11. Post-Incident Review (Multi-Stakeholder)

Area	Key Question
Root Cause	Over-privilege? Culture?
Detection Delay	Why slow?
Control Gap	Role design?
Legal / HR	Action required?
Prevention	Policy C training

12. Management-Ready Summary

Item	Example
Incident	Insider misuse detected
Impact	No confirmed data loss
Detection	Behaviour-based UEBA
Containment	Controlled
Preventive Action	Access revalidation

PLAYBOOK 8 – THIRD-PARTY G VENDOR ACCESS ABUSE

Why this playbook exists

In 2026, organisations no longer operate alone. They rely on:

- SaaS providers
- Outsourced IT and SOC vendors
- System integrators
- FinTech / GovTech partners
- API consumers

Attackers know this and target the weakest trusted link. Most third-party incidents:

- Use legitimate vendor accounts
- Bypass perimeter defences
- Appear as “authorised activity”
- Are discovered after data access

This is why SOC teams must actively investigate third-party and vendor behaviour, not just internal users.

Playbook Metadata

Item	Details
Playbook ID	SOC-APP-08
Incident Category	Third-Party / Supply-Chain Access Abuse
Primary Focus	Vendor C Partner Access
SOC Coverage	L1 → L2 → L3
Framework References	OWASP, MITRE ATTCK, NIST SP 800-61
2026 Relevance	Critical (SaaS, APIs, outsourcing, MDR)

1. What is Third-Party Access Abuse?

Third-party access abuse occurs when a vendor, partner, or service account:

- Uses granted access outside agreed scope
- Is compromised and misused by attackers
- Retains access longer than required
- Accesses systems at abnormal times or volumes

Key principle: Trust is not a control. Visibility is.

2. Typical SOC Alert Triggers

Alert Source	Trigger Example	Why It Matters
IAM	Vendor account login outside business hours	Compromise
SIEM	Vendor accessing new systems	Scope creep
UEBA	Behaviour deviation from vendor baseline	Abuse
API Gateway	Partner API spike	Data extraction
Cloud Logs	Service account mass reads	Silent exfil

3. Initial Triage – L1 SOC (Decision Gate)

Objective: Determine if activity is approved vendor work or unauthorised abuse.

Triage Question	Yes	No	Explanation
-----------------	-----	----	-------------

Triage Question	Yes	No	Explanation
Account identified as vendor?	Continue	Reclassify	Ownership clarity
Activity within contract scope?	Continue	Escalate	Abuse
Access within approved hours?	Continue	Note	Risk
Data sensitivity high?	Escalate	Continue	Impact
New systems accessed?	Escalate	Continue	Scope breach
Automation detected?	Escalate	Continue	Compromise

L1 Rule: Vendor access outside contract = incident until proven otherwise

4. Context Enrichment – L1 → L2

Context Dimension	What to Check	Why
Vendor Name	Contract owner	Accountability
Access Type	Human / service account	Abuse mode
Approved Scope	Systems C APIs	Boundary
Timing	Change window vs odd hours	Legitimacy
Data Touched	PII / internal	Severity
Geo / ASN	Expected vendor location	Compromise

5. Threat Classification

Category	Mapping
OWASP	Broken Access Control / Excessive Data Exposure
MITRE ATTCK	Initial Access → Collection
Attack Type	Supply-Chain Access Abuse
Incident Type	Third-Party Breach (Suspected / Confirmed)

Important: Most supply-chain breaches begin with valid credentials.

6. Severity Assessment (Trust-Weighted)

Factor	Low	Medium	High
Vendor Criticality	Low	Medium	High
Data Sensitivity	Internal	Confidential	Regulated
Scope Violation	Minor	Moderate	Major
Persistence	Short	Sustained	Long-term

Severity Logic: Vendor Criticality × Data Sensitivity × Scope Violation

7. Containment – L2 SOC (Coordinated)

Action	Owner	Reason
Suspend vendor account	SOC / IAM	Stop access
Revoke service tokens	SOC	Prevent automation
Block IP / ASN	SOC	Immediate
Notify contract owner	SOC	Business alignment
Engage vendor security	Vendor Mgmt	Joint response

Critical Rule: Contain first, communicate fast, document everything.

8. Evidence Preservation (Contract-Sensitive)

Evidence	Source	Purpose
Access logs	IAM / App	Proof of misuse
API usage logs	Gateway	Data scope
Service account actions	Cloud logs	Automation
UEBA profiles	SIEM	Behaviour deviation
Contract scope	Vendor Mgmt	Breach validation

Rule: Evidence must support legal, contractual, and audit review.

G. Eradication – L2 → L3

Step	Purpose
Rotate vendor credentials	Kill persistence
Reduce vendor privileges	Least privilege
Enforce time-bound access	Limit exposure
Require MFA / IP allowlists	Strong control

10. Recovery & Monitoring

Step	Validation
Legit access restored (if valid)	Contract approval

Step	Validation
New access controls applied	IAM
Monitoring window	30–60 days
No abnormal behaviour	SIEM

11. Post-Incident Review (Cross-Functional)

Area	Key Question
Root Cause	Over-trust? Poor scoping?
Detection	Timely enough?
Vendor Governance	Adequate?
Contract Gaps	Security clauses?
Improvement	Vendor access policy

12. Management-Ready Summary

Item	Example
Incident	Vendor access abuse detected
Impact	No confirmed data loss
Detection	Behaviour-based monitoring
Containment	<20 minutes
Preventive Action	Privilege reduction

PLAYBOOK G – CLOUD IAM MISCONFIGURATION EXPLOITATION

Why this playbook exists

In cloud environments, identity is the new perimeter. In 2026:

- Firewalls don't protect cloud resources
- Networks are flat by design
- APIs are the control plane
- IAM policies define everything

Most major cloud breaches happen without exploits they happen because:

- Permissions are too broad
- Trust relationships are misconfigured

- Service accounts are over-privileged
- Temporary credentials are abused

This is why SOC teams investigate cloud IAM behaviour and configuration, not just cloud malware.

Playbook Metadata

Item	Details
Playbook ID	SOC-APP-09
Incident Category	Cloud Identity C Access Abuse
Primary Focus	IAM Misconfiguration Exploitation
SOC Coverage	L1 → L2 → L3
Framework References	OWASP, MITRE ATTCK, NIST SP 800-61
2026 Relevance	Critical (AWS, Azure, GCP, SaaS IAM)

1. What is Cloud IAM Misconfiguration Exploitation?

Cloud IAM misconfiguration exploitation occurs when an attacker:

- Uses legitimate credentials
- Exploits excessive permissions
- Abuses trust relationships
- Escalates privileges through policy logic

Common examples:

- *:~ permissions on service accounts
- Misconfigured role assumption
- Overly permissive managed policies
- Unrestricted API access to sensitive services

Key principle: In the cloud, misconfiguration is the vulnerability.

2. Typical SOC Alert Triggers

Alert Source	Trigger Example	Why It Matters
CloudTrail / Activity Logs	AssumeRole from new principal	Privilege escalation
SIEM	IAM policy change outside change window	Persistence
UEBA	Admin actions by non-admin	Role abuse

Alert Source	Trigger Example	Why It Matters
Cloud Security Tool	Excessive permissions flagged	Risk
API Logs	Sensitive API calls by service account	Misuse

3. Initial Triage – L1 SOC (Decision Gate)

Objective: Decide if IAM activity is legitimate admin work or identity abuse.

Triage Question	Yes	No	Explanation
Is identity known (user/service)?	Continue	Escalate	Rogue principal
Action approved in change record?	Continue	Escalate	Unauthorized change
Privilege level increased?	Escalate	Continue	Escalation
New trust relationship?	Escalate	Continue	Lateral movement
Sensitive service accessed?	Escalate	Continue	Impact
Performed off-hours?	Continue	Note	Stealth

L1 Rule: Privilege change without approval = incident until proven otherwise

4. Context Enrichment – L1 → L2

Context Dimension	What to Check	Why
Identity Type	Human vs service account	Abuse pattern
Policy Scope	Specific vs wildcard	Blast radius
Trust Policy	Who can assume role	Escalation path
API History	Actions before C after	Timeline
Cloud Region	Expected vs unusual	Compromise
Source IP	Corporate vs external	Risk

5. Threat Classification

Category	Mapping
OWASP	Security Misconfiguration
MITRE ATTCK	Privilege Escalation → Persistence
Attack Type	IAM Privilege Escalation
Incident Type	Cloud Identity Compromise

Important: Attackers often escalate silently, then act later.

6. Severity Assessment (Privilege-Centric)

Factor	Low	Medium	High
Privilege Level	Read-only	Power user	Admin
Resource Access	Limited	Multiple	Global
Persistence	None	Temporary	Long-term
Detection Time	Fast	Moderate	Late

Severity Logic: Privilege Level × Resource Scope × Persistence

7. Containment – L2 SOC (Immediate)

Action	Owner	Reason
Revoke credentials / role	SOC / Cloud	Stop access
Roll back IAM policy	Cloud / SecEng	Remove escalation
Disable trust relationship	Cloud	Stop lateral move
Block source IP	SOC	Slow attacker
Snapshot logs C state	SOC	Forensics

Priority: Stop identity abuse first, investigate second.

8. Evidence Preservation

Evidence	Source	Purpose
IAM change logs	CloudTrail / Activity	Proof of escalation
Policy versions	Cloud IAM	Before/after
Role assumption logs	Cloud	Lateral movement
API call history	SIEM	Impact scope
UEBA context	SIEM	Behaviour anomaly

Rule: Preserve policy history not just events.

G. Eradication – L2 → L3

Step	Purpose
Apply least-privilege policies	Structural fix
Remove wildcard permissions	Reduce blast radius

Step	Purpose
Apply least-privilege policies	Structural fix
Enforce approval workflow	Prevent repeat
Rotate all credentials	Kill persistence

10. Recovery & Monitoring

Step	Validation
Legit access restored	Cloud owner sign-off
IAM baselines revalidated	Security
Monitoring window	30–60 days
No abnormal IAM actions	SIEM

11. Post-Incident Review (Cloud-Focused)

Area	Key Question
Root Cause	Over-permission? Trust misconfig?
Detection	Early enough?
Control Gap	IAM review cadence?
Tooling	CSPM / CIEM gaps?
Prevention	Policy-as-code?

12. Management-Ready Summary

Item	Example
Incident	Cloud IAM misconfiguration exploited
Impact	No data loss
Detection	Behaviour-based IAM monitoring
Containment	<15 minutes
Preventive Action	Least privilege enforced

PLAYBOOK 10 – AI-DRIVEN AUTOMATION G ABUSE

Why this playbook exists

In 2026, attackers don't "hack" one account at a time. They:

- Automate reconnaissance
- Generate payloads dynamically
- Adapt behaviour in real time
- Mimic human interaction patterns
- Scale attacks using AI agents AI removes:
 - Skill barriers
 - Speed limitations
 - Predictable patterns

This is why SOC teams now investigate automation behaviour, not just signatures.

Playbook Metadata

Item	Details
Playbook ID	SOC-APP-10
Incident Category	Automated / AI-Assisted Abuse
Primary Focus	Behavioural Automation Detection
SOC Coverage	L1 → L2 → L3
Framework References	OWASP, MITRE ATT&CK, NIST SP 800-61
2026 Relevance	Extreme (LLMs, bots, agentic attacks)

1. What is AI-Driven Abuse?

AI-driven abuse is malicious activity where:

- Decision-making is automated
- Actions adapt based on responses
- Requests appear human-like
- Scale exceeds human capability

Examples:

- AI-driven credential stuffing
- Adaptive API scraping
- Automated business logic abuse

- AI-generated phishing C MFA fatigue
- LLM-assisted enumeration

Key principle: AI doesn't break rules it optimises abuse.

2. Typical SOC Alert Triggers

Alert Source	Trigger Example	Why It Matters
SIEM	High-volume varied requests	Adaptive automation
UEBA	Behaviour oscillates to avoid thresholds	AI evasion
App Logs	Near-human interaction timing	Bot mimicry
API Gateway	Pattern mutation mid-attack	Learning agent
IAM	MFA fatigue bursts	AI-orchestrated

3. Initial Triage – L1 SOC (Decision Gate)

Objective: Identify automation intelligence, not just automation presence.

Triage Question	Yes	No	Explanation
Requests adapt after failures?	Escalate	Continue	Learning loop
Timing resembles human but scaled?	Escalate	Continue	Bot mimicry
Multiple attack types chained?	Escalate	Continue	Agent behaviour
Source diversity high?	Escalate	Continue	Botnet
Logic abuse detected?	Escalate	Continue	AI optimisation
Business impact visible?	Escalate	Continue	Severity

L1 Rule (2026): Adaptation + scale = AI-assisted until proven otherwise

4. Context Enrichment – L1 → L2

Context Dimension	What to Check	Why
Request Entropy	Payload variation	AI generation
Timing Variance	Human-like jitter	Evasion
Attack Chain	Login → API → data	Agent orchestration
Response Feedback	Behaviour changes	Learning
Source Infra	Residential / proxy	AI-friendly infra

Context Dimension	What to Check	Why
Tool Fingerprints	Headless browsers	Automation

5. Threat Classification

Category	Mapping
OWASP	Automated Threats / Business Logic Abuse
MITRE ATTCK	Reconnaissance → Impact
Attack Type	AI-Assisted Automation
Incident Type	Intelligent Abuse Campaign

Important: AI-driven attacks blend multiple OWASP categories simultaneously.

6. Severity Assessment (Speed-Weighted)

Factor	Low	Medium	High
Adaptation Speed	Slow	Moderate	Real-time
Scale	Limited	Wide	Massive
Attack Diversity	Single	Multiple	Chained
Business Impact	Minor	Moderate	Severe

Severity Logic: Speed × Scale × Adaptability

7. Containment – L2 SOC (Adaptive Response)

Action	Owner	Reason
Behaviour-based blocking	SOC	Stop AI learning
Dynamic rate limiting	Gateway	Break optimisation
CAPTCHA / challenge	App	Human verification
IP / ASN throttling	SOC	Reduce scale
Kill sessions/tokens	SOC	Stop persistence

Critical Rule: Static rules fail against adaptive attackers.

8. Evidence Preservation

Evidence	Source	Purpose
Request sequences	App / API	Learning proof
Timing analysis	SIEM	Human mimicry

Evidence	Source	Purpose
Attack chain timeline	SOC	Campaign mapping
Response adaptation logs	App	AI feedback loop
UEBA drift	SIEM	Behaviour evolution

Rule:

Capture change over time, not snapshots.

G. Eradication – L2 → L3

Step	Purpose
Introduce randomness	Break predictability
Harden business logic	Reduce abuse ROI
Implement AI-aware detection	Long-term defence
Update playbooks	SOC maturity

10. Recovery G Monitoring

Step	Validation
Legit users unaffected	Business
Abuse stopped	SOC
Monitoring window	30–90 days
No adaptive recurrence	SIEM

11. Post-Incident Review (Forward-Looking)

Area	Key Question
Root Cause	Automation gap?
Detection	Behaviour-based enough?
Controls	Static vs adaptive?
Tooling	Bot C AI defence readiness?
Strategy	AI vs AI roadmap

12. Management-Ready Summary

Item	Example
Incident	AI-driven automated abuse detected
Impact	No data loss
Detection	Behaviour C adaptation analysis
Containment	Adaptive controls
Preventive Action	AI-aware defence

PLAYBOOK 11 – SHADOW IT & UNSANCTIONED SAAS RISK

Why this playbook exists

In 2026, users don't wait for IT approval. They:

- Sign up for SaaS using work emails
- Upload corporate data to personal tools
- Sync files to unknown cloud apps
- Use AI tools outside governance Most

Shadow IT incidents:

- Involve no malware
- Use legitimate credentials
- Bypass logging and SOC visibility
- Are discovered after data exposure

This is why SOC teams must investigate unsanctioned applications and data movement, not just attacks.

Playbook Metadata

Item	Details
Playbook ID	SOC-APP-11
Incident Category	Shadow IT / Unauthorised SaaS
Primary Focus	Unsanctioned Cloud Application Usage
SOC Coverage	L1 → L2 → L3
Framework References	OWASP, MITRE ATT&CCK, NIST SP 800-61
2026 Relevance	High (Remote work, AI tools, SaaS sprawl)

1. What is Shadow IT?

Shadow IT refers to applications, services, or tools used by employees without formal IT or security approval.

Examples:

- Personal cloud storage (Drive, Dropbox)
- Unsanctioned SaaS (CRM, ticketing, analytics)
- AI tools uploading sensitive data
- Browser extensions with data access
- Personal APIs and automation tools

Key principle: If IT doesn't know about it, SOC can't protect it.

2. Typical SOC Alert Triggers

Alert Source	Trigger Example	Why It Matters
Proxy / SWG	New SaaS domain accessed	Discovery
CASB	App not in approved list	Risk
SIEM	Large uploads to unknown cloud	Data leakage
Email Logs	OAuth consent to unknown app	Token exposure
UEBA	User behaviour shift	SaaS adoption

3. Initial Triage – L1 SOC (Decision Gate)

Objective: Determine whether usage is low-risk productivity or high-risk data exposure.

Triage Question	Yes	No	Explanation
App officially approved?	Close	Continue	Governance
Corporate data involved?	Escalate	Continue	Exposure
OAuth / token granted?	Escalate	Continue	Persistent access
Data sensitivity high?	Escalate	Continue	Severity
Repeated usage?	Continue	Note	Adoption trend
External sharing enabled?	Escalate	Continue	Leakage

L1 Rule: Unsanctioned app + sensitive data = incident until assessed

4. Context Enrichment – L1 → L2

Context Dimension	What to Check	Why
-------------------	---------------	-----

Context Dimension	What to Check	Why
App Category	Storage / AI / CRM	Risk profile
Data Type	PII / internal	Compliance
Auth Method	Password vs OAuth	Persistence
Sharing Scope	Private vs public	Exposure
User Role	Job relevance	Justification
Geo / Hosting	Data residency	Regulation

5. Threat Classification

Category	Mapping
OWASP	Security Misconfiguration / Data Exposure
MITRE ATTCK	Exfiltration
Attack Type	Unauthorised Data Transfer
Incident Type	Shadow IT Exposure

Important: Shadow IT incidents are often accidental, but impact is real.

6. Severity Assessment (Data Governance-Driven)

Factor	Low	Medium	High
Data Sensitivity	Public	Internal	PII / Regulated
App Risk	Low	Medium	High
Persistence	One-time	Repeated	Continuous
Sharing Scope	Personal	Team	Public / External

Severity Logic: Data Sensitivity × App Risk × Exposure Scope

7. Containment – L2 SOC (Balanced Response)

Action	Owner	Reason
Block app via SWG/CASB	SOC	Stop usage
Revoke OAuth tokens	SOC / IAM	Remove persistence
Pause data sync	App / IT	Stop leakage
Notify user C manager	SOC	Awareness
Preserve logs	SOC	Evidence

Critical Rule: Do not disrupt business blindly confirm impact first.

8. Evidence Preservation

Evidence	Source	Purpose
Proxy logs	SWG	App usage
CASB discovery logs	CASB	App profile
OAuth consent logs	IAM	Token scope
Upload/download logs	SIEM	Data volume
UEBA baseline	SIEM	Behaviour proof

Rule: Evidence must support policy, audit, and awareness actions.

G. Eradication – L2 → L3

Step	Purpose
Remove unsanctioned access	Reduce risk
Add approved alternative	Business enablement
Update app allowlist	Governance
Enhance discovery rules	Early detection

10. Recovery & Monitoring

Step	Validation
Business workflow restored	Manager sign-off
Data exposure assessed	Security
Monitoring window	14–30 days
No recurrence	SIEM

11. Post-Incident Review

Area	Key Question
Root Cause	Tool gap? Awareness?
Detection	Early enough?
Governance	Approval process slow?
Control Gap	CASB / SWG coverage?

Area	Key Question
Prevention	SaaS onboarding flow

12. Management-Ready Summary

Item	Example
Incident	Unsanctioned SaaS usage detected
Impact	No confirmed data breach
Detection	Cloud app discovery
Containment	Controlled
Preventive Action	SaaS governance improved

Playbook 12 – Harvest Now, Decrypt Later (HN-DL) Risk

Why this playbook exists

Harvest Now, Decrypt Later is not a breach you see today. It is a breach you discover years later.

In 2026:

- Attackers capture encrypted traffic
- Store it cheaply
- Wait for quantum-capable decryption
- Decrypt historical sensitive data retroactively

No malware. No alerts.

No failed logins.

This is why SOC teams must treat mass encrypted data capture as a long-term incident, not a future problem.

Playbook Metadata

Item	Details
Playbook ID	SOC-CRYPTO-12
Incident Category	Cryptographic C Long-Term Data Risk
Primary Focus	Encrypted Data Harvesting
SOC Coverage	L2 → L3 (Strategic SOC)
Framework References	NIST, NIST SP 800-61, MITRE ATT&CK

Item	Details
2026 Relevance	Strategic C Mandatory

1. What is Harvest Now, Decrypt Later?

Harvest Now, Decrypt Later (HN-DL) is a threat model where attackers:

- Intercept encrypted traffic today
- Do not attempt decryption now
- Store data long-term
- Decrypt it once cryptography is broken (e.g. quantum computing) Key principle: Encryption only protects data until it can be broken.

2. Why SOC Teams Must Care Now (Not Later)

SOC teams traditionally ask:

“Was data decrypted or accessed?” HN-

DL forces a new question:

“Was encrypted data captured?”

Because:

- TLS ≠ future secrecy
- Long-lived data remains valuable
- Compliance timelines exceed crypto lifetimes

3. What Attackers Actually Harvest

Data Type	Why Valuable
TLS network traffic	Bulk decryption later
VPN sessions	Internal access reconstruction
Encrypted backups	Long-term archives
Encrypted databases	Regulatory exposure
Authentication handshakes	Identity reconstruction

4. Typical SOC Signals (Weak but Real)

Signal Source	Indicator	Why It Matters
Network Monitoring	Unusual packet capture volume	Data harvesting
Proxy / Gateway	Long-lived TLS sessions	Collection

Signal Source	Indicator	Why It Matters
NDR	Passive sniffing behaviour	Stealth
Cloud Logs	Bulk encrypted exports	Storage
Threat Intel	APT interest in long-term data	Intent

Important: HN-DL rarely produces strong alerts.

5. Initial Triage – L2 SOC (Strategic Gate)

Objective: Decide if activity indicates bulk encrypted data harvesting.

Triage Question	Yes	No	Explanation
Large encrypted data flows?	Continue	Monitor	Collection
No decryption attempts?	Continue	Note	HN-DL pattern
Long-term storage suspected?	Escalate	Continue	Intent
Nation-state indicators?	Escalate	Continue	Capability
Long-lived data involved?	Escalate	Continue	Risk

SOC Rule (2026): Encrypted does not mean safe.

6. Threat Classification

Category	Mapping
Cryptographic Risk	Long-Term Confidentiality Failure
MITRE ATTCK	Collection
Attack Type	Strategic Data Harvesting
Incident Type	Deferred Data Breach Risk

7. Severity Assessment (Time-Shifted)

Factor	Low	Medium	High
Data Sensitivity	Public	Internal	Regulated / PII
Data Longevity	Short	Medium	>10 years
Adversary	Criminal	Advanced	Nation-state
Volume	Small	Moderate	Massive

Severity Logic: Data Sensitivity × Longevity × Adversary Capability

8. Containment – L3 SOC (Preventive, Not Reactive)

Action	Owner	Reason
Reduce encrypted data exposure	Network / App	Minimise harvest
Enforce Perfect Forward Secrecy	Crypto / Network	Limit replay
Encrypt data at rest with agility	Crypto	Future-proofing
Segment sensitive traffic	Network	Reduce capture
Block suspicious passive monitoring	SOC	Disrupt harvesting

Key Shift: Containment = architectural, not tactical.

G. Evidence Preservation

Evidence	Source	Purpose
Network flow logs	NDR	Volume proof
TLS configs	App / Network	Crypto posture
Data classification	GRC	Risk scope
Threat intel	CTI	Attribution
Storage logs	Cloud	Exfil indicators

Rule: Preserve evidence even if no data was decrypted.

10. Eradication – Strategic (Not Immediate)

Step	Purpose
Crypto inventory	Identify weak algorithms
Shorten data retention	Reduce future blast
Plan PQC migration	Quantum readiness
Enforce algorithm agility	Future transitions

11. Recovery & Long-Term Monitoring

Step	Validation
Sensitive data minimised	Business
Crypto posture improved	Security

Step	Validation
Monitoring window	Continuous
PQC roadmap tracked	Governance

12. Management-Ready Summary

Item	Example
Incident	Encrypted data harvesting risk identified
Impact	No immediate breach
Risk	Long-term confidentiality
Action	Crypto hardening
Strategic Outcome	Quantum readiness

PLAYBOOK 13 – MFA FATIGUE, PUSH BOMBING & AUTHENTICATION ABUSE

Why this playbook exists

Multi-Factor Authentication (MFA) was designed to stop attackers.

In reality, attackers adapted.

Instead of breaking MFA, they:

- Overwhelm users with push requests
- Exploit approval fatigue
- Social-engineer trust
- Abuse fallback authentication flows

In 2026, MFA fatigue is one of the top causes of account compromise, especially for:

- VPNs
- Cloud IAM
- SaaS platforms
- Privileged users

This is why SOC teams investigate authentication abuse, not just login failures.

Playbook Metadata

Item	Details
Playbook ID	SOC-ID-13
Incident Category	Identity C Authentication Abuse

Item	Details
Primary Focus	MFA Fatigue / Push Bombing
SOC Coverage	L1 → L2 → L3
Framework References	OWASP, MITRE ATTCK, NIST SP 800-61
2026 Relevance	Extremely High (Cloud-first identity era)

1. What is MFA Fatigue / Push Bombing?

MFA fatigue occurs when an attacker:

- Already has valid credentials
- Triggers repeated MFA push requests
- Relies on user annoyance, confusion, or panic
- Gains access when the user finally approves

Variants include:

- Push bombing
- MFA spamming
- MFA prompt hijacking
- Social engineering combined with MFA

Key principle: MFA protects systems, but users still approve access.

2. Typical SOC Alert Triggers

Alert Source	Trigger Example	Why It Matters
IAM / IDP	Dozens of MFA push requests	Fatigue pattern
SIEM	Repeated failed MFA → success	Breakthrough
UEBA	Login success after abnormal MFA volume	Abuse
VPN Logs	MFA prompts outside work hours	Social engineering
Helpdesk Tickets	"I keep getting MFA requests"	Early signal

3. Initial Triage – L1 SOC (Decision Gate)

Objective: Identify MFA abuse in progress, not after compromise.

Triage Question	Yes	No	Explanation
-----------------	-----	----	-------------

Triage Question	Yes	No	Explanation
Multiple MFA pushes in short time?	Escalate	Continue	Fatigue
User denies then approves?	Escalate	Continue	Breakthrough
Login from new geo/device?	Escalate	Continue	Compromise
Privileged account involved?	Escalate	Continue	Impact
Off-hours activity?	Escalate	Continue	Social pressure

L1 Rule (2026): MFA spam = active attack, not noise

4. Context Enrichment – L1 → L2

Context Dimension	What to Check	Why
MFA Type	Push / OTP / FIDO2	Resistance
Approval Method	One-tap vs number-matching	Weakness
Device Change	New phone/browser	Hijack
Geo / ASN	Residential / proxy	Credential theft
User Role	Admin / finance	Blast radius
Prior Phishing	Credential source	Root cause

5. Threat Classification

Category	Mapping
OWASP	Broken Authentication
MITRE ATTCK	Credential Access → Initial Access
Attack Type	MFA Fatigue / Push Bombing
Incident Type	Account Compromise (Attempted / Confirmed)

Important: MFA fatigue attacks often succeed within minutes

6. Severity Assessment (Identity-Centric)

Factor	Low	Medium	High
Account Type	Normal user	Power user	Admin
MFA Strength	Number-matching	Push only	Weak / fallback
Behaviour	Early stage	Breakthrough	Active misuse
Data Access	None	Limited	Sensitive

Severity Logic: Account Privilege × MFA Weakness × Behaviour

7. Containment – L2 SOC (Immediate G User-Centric)

Action	Owner	Reason
Disable account temporarily	SOC	Stop attack
Reset credentials	SOC / IAM	Kill attacker
Revoke sessions C tokens	SOC	Stop persistence
Enforce strong MFA	IAM	Structural fix
Block source IP/ASN	SOC	Reduce retries

Critical Rule: Containment must be faster than user frustration.

8. Evidence Preservation

Evidence	Source	Purpose
MFA logs	IAM	Abuse pattern
Login history	IAM	Breakthrough
UEBA score	SIEM	Behaviour anomaly
IP intelligence	CTI	Attribution
User reports	Helpdesk	Timeline

Rule: Preserve MFA denial/approval sequences.

G. Eradication – L2 → L3

Step	Purpose
Enforce phishing-resistant MFA	Stop fatigue
Disable push-only MFA	Reduce abuse
Implement number matching	User verification
Add MFA rate limiting	Prevent spam

10. Recovery G Monitoring

Step	Validation
User access restored	Verified identity

Step	Validation
MFA posture hardened	IAM
Monitoring window	14–30 days
No repeat prompts	SIEM

11. Post-Incident Review

Area	Key Question
Root Cause	Credential phishing?
Detection Speed	Early enough?
User Awareness	Clear guidance?
Control Gap	MFA too permissive?
Prevention	Phishing-resistant MFA

12. Management-Ready Summary

Item	Example
Incident	MFA fatigue attack detected
Impact	No data loss
Detection	MFA behaviour monitoring
Containment	<5 minutes
Preventive Action	Strong MFA enforced

PLAYBOOK 14 – RANSOMWARE WITHOUT MALWARE (LIVING-OFF-THE-LAND ATTACKS)

Why this playbook exists

Modern ransomware operators no longer rely on:

- Dropped malware
- Exploit kits
- Suspicious binaries Instead, they:
- Use built-in system tools
- Abuse legitimate admin utilities
- Blend into normal IT operations

- Encrypt data using trusted processes This is known as Living-off-the-Land (LotL). In 2026, many ransomware incidents:
- Trigger no antivirus alerts
- Look like routine admin activity
- Are detected too late, during encryption

This is why SOC teams must investigate behavioural misuse of legitimate tools, not just malware.

Playbook Metadata

Item	Details
Playbook ID	SOC-ENDP-14
Incident Category	Ransomware / Impact
Primary Focus	Living-off-the-Land Abuse
SOC Coverage	L1 → L2 → L3
Framework References	MITRE ATT&CK, NIST SP 800-61, OWASP
2026 Relevance	Extremely High (EDR-evasion era)

1. What is “Ransomware Without Malware”?

Ransomware without malware occurs when attackers:

- Gain valid access (credentials, tokens, VPN)
- Use built-in tools (PowerShell, WMIC, VSS, BitLocker, robocopy)
- Disable backups and recovery
- Encrypt or destroy data using trusted utilities No suspicious executable is required.

Key principle: If tools are trusted, behaviour becomes the indicator.

2. Common Living-off-the-Land Tools Abused

Tool	Legitimate Use	Abused Purpose
PowerShell	Automation	Mass encryption, lateral movement
WMIC	Management	Remote execution
Psexec	Admin tasks	Payload-less execution
VSSAdmin	Backup mgmt	Delete shadow copies

Tool	Legitimate Use	Abused Purpose
BitLocker	Disk encryption	Host-level ransom
Robocopy	File transfer	Data staging

3. Typical SOC Alert Triggers

Alert Source	Trigger Example	Why It Matters
EDR	PowerShell running encoded commands	Obfuscation
SIEM	VSSAdmin delete shadows	Pre-ransom
Windows Logs	Psexec from non-admin host	Lateral movement
File Monitoring	Rapid file rename/encrypt	Impact
UEBA	Admin behaviour anomaly	Compromise

4. Initial Triage – L1 SOC (Decision Gate)

Objective: Detect pre-encryption behaviour, not ransom note appearance.

Triage Question	Yes	No	Explanation
Legit tool used abnormally?	Escalate	Continue	LotL signal
Admin tool outside change window?	Escalate	Continue	Abuse
Backup deletion detected?	Escalate	Continue	Ransom prep
Lateral execution observed?	Escalate	Continue	Spread
File ops spike?	Escalate	Continue	Encryption

L1 Rule (2026): Backup destruction = ransomware until proven otherwise

5. Context Enrichment – L1 → L2

Context Dimension	What to Check	Why
User Account	IT admin vs normal	Expectation
Host Role	Server / workstation	Impact
Command Line	Encoded / hidden	Obfuscation
Sequence	Recon → backup delete → encrypt	Ransom chain

Context Dimension	What to Check	Why
Time	Off-hours	Stealth
Privilege	SYSTEM/ admin	Capability

6. Threat Classification

Category	Mapping
MITRE ATTCK	Execution → Impact
OWASP	Security Misconfiguration
Attack Type	Living-off-the-Land Ransomware
Incident Type	Active Ransomware (No Malware)

Important: LotL ransomware bypasses signature-based security by design.

7. Severity Assessment (Time-Critical)

Factor	Low	Medium	High
Spread	Single host	Few hosts	Network-wide
Backup Status	Intact	Partial	Destroyed
Privilege	User	Local admin	Domain admin
Encryption Stage	Not started	Partial	Active

Severity Logic: Privilege × Spread × Backup Status

8. Containment – L2 SOC (Immediate, Aggressive)

Action	Owner	Reason
Isolate affected host(s)	SOC	Stop spread
Disable compromised accounts	IAM	Kill access
Block admin tools temporarily	SOC	Stop encryption
Suspend network shares	IT	Protect data
Preserve volatile evidence	SOC	Forensics

Critical Rule: Speed matters more than attribution.

G. Evidence Preservation

Evidence	Source	Purpose
Command-line logs	EDR/Sysmon	Abuse proof
Event logs	Windows	Timeline
File change logs	EDR	Impact
Network logs	SIEM	Lateral spread
Backup logs	IT	Recovery viability

Rule: Capture commands and sequence, not binaries.

10. Eradication – L2 → L3

Step	Purpose
Reset all affected credentials	Remove persistence
Rebuild compromised hosts	Trust reset
Restore from clean backups	Recovery
Remove excessive privileges	Reduce blast

11. Recovery & Monitoring

Step	Validation
Systems restored	IT sign-off
Data integrity confirmed	Business
Monitoring window	30–60 days
No repeat LotL patterns	SIEM

12. Post-Incident Review

Area	Key Question
Entry Point	Credential theft?
Detection	Pre-encryption caught?
Control Gaps	Admin tool misuse?
Improvement	Behavioural rules

Area	Key Question
Training	SOC C IT

13. Management-Ready Summary

Item	Example
Incident	Ransomware without malware detected
Impact	Limited encryption
Detection	Behavioural LotL monitoring
Containment	<10 minutes
Preventive Action	Admin tool controls

PLAYBOOK 15 – EMAIL-BASED SOCIAL ENGINEERING AT SCALE

Why this playbook exists

Email remains the highest-ROI attack vector. In 2026, attackers:

- Personalise emails using leaked data and AI
- Rotate infrastructure automatically
- Blend phishing, BEC, and MFA fatigue
- Move from email → identity → application abuse in minutes Most successful email attacks:
- Contain no malware
- Use valid sender infrastructure
- Bypass SPF/DKIM/DMARC
- Succeed through psychology and timing

This is why SOC teams must investigate email behaviour and downstream impact, not just malicious attachments.

Playbook Metadata

Item	Details
Playbook ID	SOC-EMAIL-15
Incident Category	Social Engineering
Primary Focus	Phishing / BEC / AI-assisted Email Abuse
SOC Coverage	L1 → L2 → L3
Framework References	OWASP, MITRE ATT&CK, NIST SP 800-61

Item	Details
2026 Relevance	Extreme (AI-generated, campaign-driven)

1. What is Email-Based Social Engineering at Scale?

This threat involves coordinated, automated email campaigns that:

- Impersonate trusted identities (CEO, vendor, IT)
- Adapt content based on user responses
- Chain attacks (email → MFA fatigue → login → data)

Common variants:

- Business Email Compromise (BEC)
- Invoice C payment redirection
- OAuth consent phishing
- HR/IT impersonation
- AI-generated spear phishing

Key principle: Email is the ignition point; identity abuse is the explosion.

2. Typical SOC Alert Triggers

Alert Source	Trigger Example	Why It Matters
Email Gateway	High-confidence phishing detected	Initial access
SIEM	Multiple users receive similar lures	Campaign
IAM	Login attempts after email click	Identity pivot
UEBA	User behaviour changes post-email	Compromise
Finance Systems	Payment change requests	BEC impact

3. Initial Triage – L1 SOC (Decision Gate)

Objective: Identify campaign-level risk, not single emails.

Triage Question	Yes	No	Explanation
Multiple recipients targeted?	Escalate	Continue	Campaign
Sender impersonates trusted role?	Escalate	Continue	Authority abuse
Link leads to credential/OAuth page?	Escalate	Continue	Account takeover

Triage Question	Yes	No	Explanation
Follow-up actions detected?	Escalate	Continue	Active exploitation
Finance or HR involved?	Escalate	Continue	High impact

L1 Rule (2026): One phishing email is noise; correlated emails are an incident.

4. Context Enrichment – L1 → L2

Context Dimension	What to Check	Why
Sender Profile	Domain age, look-alike	Impersonation
Email Content	Urgency, authority, secrecy	Social cues
Target Group	Execs, finance, IT	Intent
Click Behaviour	Who clicked, when	Exposure
OAuth Scopes	If consented	Persistence
Infrastructure	Hosting, redirects	Campaign scale

5. Threat Classification

Category	Mapping
OWASP	Broken Authentication / Social Engineering
MITRE ATT&CK	Initial Access → Credential Access
Attack Type	Phishing / BEC / OAuth Abuse
Incident Type	Social Engineering Campaign

Important: Email attacks rarely end at email they pivot fast.

6. Severity Assessment (Blast-Radius Based)

Factor	Low	Medium	High
Target Count	Single user	Team	Org-wide
Role Targeted	Staff	Manager	Exec / Finance
Follow-on Actions	None	Login attempts	Financial / data
Automation	Manual	Semi-auto	Fully automated

Severity Logic: Target Role × Campaign Scale × Follow-on Impact

7. Containment – L2 SOC (Rapid G Coordinated)

Action	Owner	Reason
--------	-------	--------

Action	Owner	Reason
Quarantine all related emails	SOC	Stop spread
Block sender domains/URLs	SOC	Kill campaign
Reset exposed credentials	IAM	Prevent takeover
Revoke OAuth consents	SOC	Remove persistence
Alert finance / HR	SOC	Prevent fraud

Critical Rule: Contain the campaign, not just the inbox

8. Evidence Preservation

Evidence	Source	Purpose
Email headers & bodies	Gateway	Attribution
Click & credential logs	IAM / SIEM	Exposure
OAuth consent logs	IAM	Persistence
UEBA timelines	SIEM	Behaviour change
Financial requests	ERP	Impact

Rule: Preserve the entire kill chain, not just the email.

G. Eradication – L2 → L3

Step	Purpose
Reset affected accounts	Kill access
Remove malicious inbox rules	Stop forwarding
Harden email authentication	Reduce spoofing
Add campaign detection rules	Early warning

10. Recovery & Monitoring

Step	Validation
Users re-enabled safely	IAM

Step	Validation
Finance changes reversed	Business
Monitoring window	30 days
No follow-up abuse	SIEM

11. Post-Incident Review

Area	Key Question
Root Cause	Phishing success factors?
Detection	Campaign identified early?
Controls	Email vs identity gap?
Training	Targeted awareness?
Tooling	AI-phish readiness?

12. Management-Ready Summary

Item	Example
Incident	Email social engineering campaign detected
Impact	No financial loss
Detection	Correlation across email C IAM
Containment	<15 minutes
Preventive Action	Campaign-level rules

PLAYBOOK 16 – DATA POISONING & INTEGRITY ATTACKS

Why this playbook exists

In 2026, organisations increasingly rely on:

- Analytics dashboards
- Automated decision engines
- Fraud scoring
- AI/ML models
- Compliance and audit logs

Attackers no longer need to steal data. They can silently change it.

Most data poisoning incidents:

- Use valid access

- Trigger no alarms
- Produce “successful” system behaviour
- Are discovered after bad decisions are made

This is why SOC teams investigate data integrity, not just confidentiality.

Playbook Metadata

Item	Details
Playbook ID	SOC-DATA-16
Incident Category	Integrity Compromise
Primary Focus	Data Poisoning / Integrity Abuse
SOC Coverage	L2 → L3 (with App, Data, AI teams)
Framework References	MITRE ATT&CCK, NIST SP 800-61, OWASP
2026 Relevance	High (AI, analytics, automation-driven orgs)

1. What is Data Poisoning / Integrity Attack?

A data integrity attack occurs when an attacker:

- Modifies data without authorisation, or
- Uses authorised access to inject false, misleading, or biased data

Targets include:

- Transaction records
- Logs and audit trails
- Analytics datasets
- AI/ML training data
- Configuration and reference data

Key principle: If data lies, systems make the wrong decisions.

2. Common Data Poisoning Scenarios

Scenario	Impact
Tampered audit logs	Hide attacker activity
Poisoned training data	Biased AI decisions
Fake transactions	Financial fraud
Altered reference data	System-wide errors
Manipulated metrics	Executive misdirection

3. Typical SOC Alert Triggers

Alert Source	Trigger Example	Why It Matters
SIEM	Log gaps or reordering	Tampering
UEBA	User editing data outside role	Abuse
App Logs	High-volume updates	Injection
DB Monitoring	UPDATE/DELETE spike	Integrity loss
AI Ops	Model drift unexplained	Poisoned input

4. Initial Triage – L1/L2 SOC (Decision Gate)

Objective: Decide whether anomalies are data quality issues or intentional manipulation.

Triage Question	Yes	No	Explanation
Data changed without ticket/change?	Escalate	Continue	Unauthorised
Changes affect decisions?	Escalate	Continue	Impact
User role permits changes?	Continue	Escalate	Abuse
Pattern systematic?	Escalate	Continue	Poisoning
Source external or automated?	Escalate	Continue	Attack surface

SOC Rule (2026): Silent data changes are more dangerous than noisy breaches.

5. Context Enrichment – L2 SOC

Context Dimension	What to Check	Why
Data Owner	Business accountability	Validation
Change Vector	UI / API / ETL	Entry point
Frequency	Gradual vs burst	Stealth
Scope	Single table vs system-wide	Impact
Downstream Use	AI, finance, reporting	Risk
Versioning	Rollback possible?	Recovery

6. Threat Classification

Category	Mapping
MITRE ATTCK	Impact

Category	Mapping
OWASP	Data Integrity Failure
Attack Type	Data Poisoning
Incident Type	Integrity Breach

Important: Integrity attacks often coexist with access abuse but are missed if SOC only looks for exfiltration.

7. Severity Assessment (Decision-Impact Driven)

Factor	Low	Medium	High
Data Criticality	Low	Medium	High
Decision Dependency	Informational	Operational	Automated / AI
Scope	Local	Multi-system	Enterprise-wide
Detectability	Easy	Moderate	Hard

Severity Logic: Decision Impact × Scope × Stealth

8. Containment – L2 SOC (Precision Required)

Action	Owner	Reason
Freeze affected datasets	Data / App	Stop spread
Restrict write permissions	IAM	Prevent further poisoning
Suspend automated pipelines	Data Ops	Stop propagation
Snapshot data state	SOC	Forensics
Notify data owners	SOC	Business validation

Critical Rule: Do not blindly restore without understanding contamination scope.

G. Evidence Preservation

Evidence	Source	Purpose
Before/after data versions	DB / Storage	Proof
Change logs	App / ETL	Attribution
User/API access logs	IAM	Intent
Model metrics	MLOps	Impact

Evidence	Source	Purpose
SIEM timelines	SOC	Correlation

Rule: Evidence must show how decisions were altered, not just who changed data.

10. Eradication – L2 → L3

Step	Purpose
Remove malicious entries	Clean dataset
Rebuild from trusted baseline	Integrity restore
Retrain AI models	Remove bias
Enforce immutability	Prevent repeat

11. Recovery & Monitoring

Step	Validation
Business outputs corrected	Owners
Dashboards reconciled	Analytics
Monitoring window	30–90 days
No unexplained drift	SIEM / MLOps

12. Post-Incident Review

Area	Key Question
Root Cause	Over-privilege? Pipeline gap?
Detection	Integrity alerts sufficient?
Control Gap	Write access too broad?
Prevention	Immutability, checksums?
Governance	Data stewardship clarity?

13. Management-Ready Summary

Item	Example
Incident	Data integrity compromise detected
Impact	Decision bias prevented
Detection	Behaviour C integrity monitoring

Item	Example
Containment	Controlled
Preventive Action	Write access hardening

PLAYBOOK 17 – DEEPFAKE, VOICE & IDENTITY IMPERSONATION ATTACKS

Why this playbook exists

In 2026, attackers no longer just pretend to be someone. They sound like them. They look like them. They know how they speak.

Advances in AI allow attackers to:

- Clone executive voices from public audio
- Generate convincing video calls
- Mimic writing styles and speech patterns
- Orchestrate real-time social engineering Most deepfake incidents:
- Involve no malware
- Use legitimate communication channels
- Exploit urgency and authority
- Succeed within minutes

This is why SOC teams must investigate identity impersonation, not just technical compromise.

Playbook Metadata

Item	Details
Playbook ID	SOC-SOCENG-17
Incident Category	Social Engineering / Identity Abuse
Primary Focus	Deepfake Voice, Video C Impersonation
SOC Coverage	L1 → L2 → L3 (with Legal, HR, Finance)
Framework References	OWASP, MITRE ATT&CK, NIST SP 800-61
2026 Relevance	Extreme (AI-assisted fraud era)

1. What is a Deepfake / Impersonation Attack?

A deepfake or impersonation attack occurs when an attacker:

- Uses AI-generated voice, video, or text
- Impersonates a trusted individual (CEO, CFO, vendor)
- Pressures victims into immediate action

- Bypasses technical controls using human trust
Common forms:
- Voice phishing (vishing)
- Fake video calls
- Executive impersonation
- Vendor payment redirection
- Emergency HR requests

Key principle: If identity can be faked, trust must be verified.

2. Common Deepfake G Impersonation Scenarios

Scenario	Impact
CEO voice requests urgent transfer	Financial fraud
Fake vendor call changes bank details	Payment redirection
Video call “approves” sensitive action	Policy bypass
AI-written messages mimic exec style	Decision manipulation
Hybrid email + call attack	Credibility boost

3. Typical SOC Alert Triggers

Alert Source	Trigger Example	Why It Matters
Finance Systems	Urgent payment outside process	Fraud
Helpdesk	“Executive” requests password reset	Identity abuse
Email / Chat	Authority-based urgent language	Social cue
UEBA	Behaviour deviates post-call	Compromise
CTI	Active deepfake campaigns reported	Threat context

4. Initial Triage – L1 SOC (Decision Gate)

Objective: Identify impersonation risk in real time, not after loss.

Triage Question	Yes	No	Explanation
Urgency + authority present?	Escalate	Continue	Social engineering
Request bypasses process?	Escalate	Continue	Red flag
Identity unverified technically?	Escalate	Continue	Impersonation
Channel unusual?	Escalate	Continue	Attack surface
Financial or access impact?	Escalate	Continue	Severity

L1 Rule (2026): Urgent authority requests without verification = incident until proven otherwise

5. Context Enrichment – L1 → L2

Context Dimension	What to Check	Why
Impersonated Role	CEO, CFO, vendor	Target value
Communication Channel	Voice, video, chat	Detection limits
Timing	Off-hours / travel	Plausibility
Content Style	Known phrasing	AI mimicry
Prior Recon	Public audio/video	Feasibility
Confirmation Attempts	Refused or discouraged	Red flag

6. Threat Classification

Category	Mapping
OWASP	Social Engineering / Broken Authentication
MITRE ATTCK	Initial Access → Impact
Attack Type	AI-Driven Impersonation
Incident Type	Fraud / Identity Abuse

Important: Deepfake attacks succeed by short-circuiting verification.

7. Severity Assessment (Trust-Impact Based)

Factor	Low	Medium	High
Impersonated Role	Staff	Manager	Executive
Requested Action	Info	Access	Payment / Data
Urgency	Low	Medium	Extreme

Factor	Low	Medium	High
Verification Resistance	None	Some	Strong

Severity Logic: Role Criticality × Action Impact × Urgency

8. Containment – L2 SOC (Human-Centric)

Action	Owner	Reason
Halt requested action	SOC / Business	Prevent loss
Verify identity out-of-band	SOC	Truth check
Alert finance / HR immediately	SOC	Stop execution
Preserve communications	SOC	Evidence
Notify impersonated person	SOC	Awareness

Critical Rule: Containment often means slowing humans down, not blocking systems.

G. Evidence Preservation

Evidence	Source	Purpose
Call recordings / messages	Telecom / Chat	Forensics
Email / chat metadata	Gateway	Attribution
Transaction requests	ERP	Impact
UEBA timelines	SIEM	Behaviour change
Threat intel	CTI	Campaign linkage

Rule: Preserve voice, video, and text not just logs.

10. Eradication – L2 → L3

Step	Purpose
Invalidate compromised trust paths	Stop repeat
Enforce dual approval	Reduce fraud
Restrict emergency overrides	Close gap

Step	Purpose
Update impersonation playbooks	SOC readiness

11. Recovery G Monitoring

Step	Validation
Normal operations resumed	Business
Financial exposure assessed	Finance
Monitoring window	30–60 days
No repeat attempts	SOC

12. Post-Incident Review (Cross-Functional)

Area	Key Question
Root Cause	Trust-based gap?
Detection	Early enough?
Controls	Verification process weak?
Training	Exec C staff awareness?
Tooling	Deepfake detection needed?

13. Management-Ready Summary

Item	Example
Incident	AI impersonation attempt detected
Impact	No financial loss
Detection	Behaviour C authority cues
Containment	Immediate
Preventive Action	Out-of-band verification

PLAYBOOK 18 – DESTRUCTIVE ATTACKS G DATA WIPING (IMPACT-DRIVEN)

Why this playbook exists

Not all attackers want money. Not all attackers want data.

Some attackers want:

- Business paralysis
- Loss of trust
- Operational chaos
- Irreversible damage

In 2026, destructive attacks are increasingly associated with:

- Geopolitical tension
- Hacktivism
- Insider retaliation
- Cover-up of larger breaches These attacks:
- Do not negotiate
- Do not exfiltrate visibly
- Do not wait

This is why SOC teams must treat destructive behaviour as a highest-priority incident, even if no data theft is observed.

Playbook Metadata

Item	Details
Playbook ID	SOC-IMPACT-18
Incident Category	Destructive / Impact
Primary Focus	Data Wiping, System Destruction
SOC Coverage	L1 → L2 → L3 → Crisis Management
Framework References	MITRE ATT&CK, NIST SP 800-61, OWASP
2026 Relevance	High (Geopolitical, Insider, Hybrid attacks)

1. What is a Destructive / Data Wiping Attack?

A destructive attack is one where the attacker's primary objective is impact, not persistence or profit.

This includes:

- Disk wiping
- Database deletion
- Backup destruction
- Configuration sabotage
- Firmware corruption

- Log destruction to erase traces Unlike ransomware:
- Recovery may be impossible
- There may be no communication
- Speed matters more than analysis

Key principle: When attackers destroy, containment must outrun analysis.

2. Common Destructive Attack Scenarios

Scenario	Impact
Mass deletion of cloud resources	Business outage
Wiper malware execution	Irreversible data loss
Backup repositories wiped	No recovery path
Hypervisor destruction	Multi-system failure
Log and audit wiping	Forensic blind spots

3. Typical SOC Alert Triggers

Alert Source	Trigger Example	Why It Matters
SIEM	DELETE / DROP spike	Data destruction
EDR	Disk overwrite behaviour	Wiper
Cloud Logs	Bulk resource deletion	Sabotage
Backup Systems	Backup deletion attempts	Pre-impact
UEBA	Admin performing mass destructive actions	Insider or compromise

4. Initial Triage – L1 SOC (Decision Gate)

Objective: Decide within minutes if this is accidental admin error or intentional destruction.

Triage Question	Yes	No	Explanation
Destructive commands observed?	Escalate	Continue	High impact
Outside change window?	Escalate	Continue	Abuse
Multiple systems affected?	Escalate	Continue	Coordinated

Triage Question	Yes	No	Explanation
Destructive commands observed?	Escalate	Continue	High impact
Backups targeted?	Escalate	Continue	Intent
Logs deleted or disabled?	Escalate	Continue	Cover-up

L1 Rule (2026): Mass deletion + no ticket = destructive incident until proven otherwise

5. Context Enrichment – L1 → L2

Context Dimension	What to Check	Why
Actor	Insider vs external	Response path
Privilege Level	Root / Admin	Capability
Blast Radius	Single system vs estate	Severity
Timing	During crisis / off-hours	Motivation
Prior Indicators	Ransom? Espionage?	Attribution

6. Threat Classification

Category	Mapping
MITRE ATT&CK	Impact
OWASP	Security Misconfiguration / Abuse
Attack Type	Data Wiper / Destructive Attack
Incident Type	Critical Availability Breach

Important: Destructive attacks often follow failed extortion or espionage.

7. Severity Assessment (Availability-Centric)

Factor	Low	Medium	High
Systems Affected	Few	Multiple	Enterprise-wide
Data Recoverability	Full	Partial	None
Backup Status	Safe	At risk	Destroyed
Business Impact	Degraded	Outage	Shutdown

Severity Logic: Availability Impact × Recoverability × Scope

8. Containment – L2/L3 SOC (Extreme Urgency)

Action	Owner	Reason
--------	-------	--------

Action	Owner	Reason
Isolate affected systems immediately	SOC	Stop spread
Revoke all suspected credentials	IAM	Kill access
Freeze cloud control plane	Cloud Sec	Stop deletion
Disable automation pipelines	IT / DevOps	Prevent cascade
Preserve volatile memory if possible	SOC	Attribution

Critical Rule: Containment > evidence > recovery. If you hesitate, you lose data forever.

G. Evidence Preservation (What's Left)

Evidence	Source	Purpose
Cloud activity logs	CSP	Timeline
EDR telemetry	Endpoint	Wiper proof
Backup system logs	Backup	Destruction scope
IAM logs	Identity	Actor
Network flows	SIEM	Command source

Rule: Assume evidence is being destroyed collect fast.

10. Eradication – L3 (Trust Reset)

Step	Purpose
Rebuild systems from known-good images	Remove implants
Rotate all credentials	Kill persistence
Re-establish clean IAM baselines	Prevent repeat
Re-secure backups with immutability	Future resilience

11. Recovery & Crisis Management

Step	Validation
------	------------

Step	Validation
Business continuity invoked	Management
Systems restored	IT
Data integrity verified	Owners
Public / regulatory comms prepared	Legal / Comms

12. Post-Incident Review (Executive-Level)

Area	Key Question
Root Cause	Insider? External compromise?
Detection	Early enough?
Backup Strategy	Immutable? Tested?
Control Gaps	Privilege, logging, change
Preparedness	Wiper-ready?

13. Management-Ready Summary

Item	Example
Incident	Destructive cyber attack detected
Impact	Partial service outage
Detection	Behaviour-based destructive actions
Containment	Immediate
Preventive Action	Immutable backups

PLAYBOOK 1G – SAAS-TO-SAAS LATERAL MOVEMENT (IDENTITY-DRIVEN)

Why this playbook exists

In 2026, attackers don't move laterally across servers.

They move across applications.

Modern organisations rely on:

- Multiple SaaS platforms
- SSO and OAuth federation
- API-to-API integrations
- Third-party SaaS connectors

Once an attacker compromises one SaaS identity, they can:

- Pivot silently into other SaaS platforms
- Abuse OAuth trust relationships
- Exfiltrate data without touching endpoints
- Bypass network and EDR controls entirely

This is why SOC teams must investigate identity-based lateral movement across SaaS, not just host or network movement.

Playbook Metadata

Item	Details
Playbook ID	SOC-SAAS-19
Incident Category	Identity-Driven Lateral Movement
Primary Focus	SaaS-to-SaaS Pivoting
SOC Coverage	L1 → L2 → L3
Framework References	OWASP, MITRE ATT&CK, NIST SP 800-61
2026 Relevance	Critical (SSO, OAuth, SaaS sprawl era)

1. What is SaaS-to-SaaS Lateral Movement?

SaaS-to-SaaS lateral movement occurs when an attacker:

- Compromises one SaaS account
- Uses SSO, OAuth tokens, or API trust
- Accesses additional SaaS platforms
- Expands reach without re-authenticating

Examples:

- Phished Microsoft 365 account → Salesforce access
- OAuth consent abuse → data pulled from multiple SaaS
- Compromised HR system → payroll or finance SaaS
- Email access → automated app integrations abused

Key principle: In SaaS ecosystems, trust relationships are the network.

2. Common SaaS Lateral Movement Paths

Initial Compromise	Lateral Pivot	Impact
Email SaaS	CRM / HR SaaS	Data breach
OAuth app	File storage	Mass exfiltration

Initial Compromise	Lateral Pivot	Impact
ITSM SaaS	Cloud admin portals	Privilege escalation
Collaboration tool	Internal workflows	Social engineering
Marketing SaaS	Customer databases	Regulatory exposure

3. Typical SOC Alert Triggers

Alert Source	Trigger Example	Why It Matters
IAM / IDP	OAuth app granted broad scopes	Trust abuse
SIEM	Same user active across many SaaS rapidly	Lateral movement
CASB	New SaaS access pattern	Pivot
UEBA	Identity behaviour shift across apps	Account misuse
SaaS Audit Logs	API access spike post-login	Automation

4. Initial Triage – L1 SOC (Decision Gate)

Objective: Detect identity pivoting, not isolated SaaS activity.

Triage Question	Yes	No	Explanation
Same identity active in multiple SaaS?	Escalate	Continue	Pivot
OAuth tokens issued recently?	Escalate	Continue	Persistence
Access without re-login?	Escalate	Continue	SSO abuse
Data accessed outside role?	Escalate	Continue	Impact
New SaaS never used before?	Escalate	Continue	Expansion

L1 Rule (2026): One identity, many platforms, short time window = lateral movement

5. Context Enrichment – L1 → L2

Context Dimension	What to Check	Why
Identity Type	Human vs service	Abuse pattern
Authentication Method	Password, SSO, OAuth	Control bypass
SaaS Category	Email, HR, Finance	Risk
Token Scope	Read vs admin	Blast radius

Context Dimension	What to Check	Why
Identity Type	Human vs service	Abuse pattern
Timeline	Sequential vs parallel	Automation
Data Touched	PII, financial	Severity

6. Threat Classification

Category	Mapping
OWASP	Broken Authentication / Excessive Data Exposure
MITRE ATTCK	Lateral Movement → Collection
Attack Type	SaaS Lateral Movement
Incident Type	Cross-Platform Identity Compromise

Important: SaaS lateral movement often leaves no endpoint artefacts.

7. Severity Assessment (Trust-Expansion Based)

Factor	Low	Medium	High
SaaS Count	One	Few	Many
SaaS Sensitivity	Low	Medium	High
Token Privilege	Limited	Broad	Admin
Automation	Manual	Semi	Fully automated

Severity Logic: Platform Spread × Data Sensitivity × Token Scope

8. Containment – L2 SOC (Identity-Focused)

Action	Owner	Reason
Disable compromised identity	SOC / IAM	Stop pivot
Revoke all OAuth tokens	SOC	Kill trust
Terminate active SaaS sessions	SOC	Immediate
Block suspicious OAuth apps	SOC	Prevent spread
Notify SaaS owners	SOC	Coordination

Critical Rule: Contain identity, not individual applications.

G. Evidence Preservation

Evidence	Source	Purpose
OAuth consent logs	IAM	Trust mapping
SaaS audit logs	Each platform	Impact
Session timelines	IDP	Pivot proof
UEBA cross-app profile	SIEM	Behaviour
API usage logs	SaaS	Exfil scope

Rule: Preserve cross-SaaS timelines attackers exploit gaps between logs.

10. Eradication – L2 → L3

Step	Purpose
Rotate identity credentials	Kill access
Re-approve SaaS integrations	Trust reset
Reduce OAuth scopes	Least privilege
Enforce conditional access	Prevent repeat

11. Recovery & Monitoring

Step	Validation
Legit SaaS access restored	Business
Integrations reviewed	IT / App owners
Monitoring window	30–60 days
No abnormal pivots	SIEM

12. Post-Incident Review

Area	Key Question
Root Cause	Phishing? OAuth abuse?
Detection	Cross-SaaS visibility adequate?
Control Gap	SSO / OAuth oversight?
Governance	SaaS inventory complete?

Area	Key Question
Tooling	CASB / SSPM needed?

13. Management-Ready Summary

Item	Example
Incident	SaaS-to-SaaS lateral movement detected
Impact	No confirmed data loss
Detection	Identity correlation across SaaS
Containment	<15 minutes
Preventive Action	OAuth scope reduction

PLAYBOOK 20 – SOC BLIND SPOTS G LOG EVASION

Why this playbook exists

Attackers don't always hide in logs. Sometimes they remove the logs, bypass them, or operate where logs don't exist.

In 2026:

- Cloud control planes generate massive telemetry
- SaaS logs are fragmented and delayed
- APIs and serverless often lack deep visibility
- Attackers actively tamper with logging

Most major breaches include at least one blind spot:

- Logging disabled or misconfigured
- Retention too short
- Telemetry never onboarded to SIEM
- Logs overwritten or deleted

This is why SOC teams must investigate absence of evidence as evidence.

Playbook Metadata

Item	Details
Playbook ID	SOC-META-20
Incident Category	Evasion / Defense Bypass
Primary Focus	Log Evasion C Telemetry Blind Spots
SOC Coverage	L1 → L2 → L3 (with Platform C Cloud teams)

Item	Details
Framework References	MITRE ATT&CK, NIST SP 800-61, OWASP
2026 Relevance	Extreme (Cloud, SaaS, API-first estates)

1. What are SOC Blind Spots & Log Evasion?

SOC blind spots are areas where:

- Activity occurs but is not logged
- Logs exist but are not collected
- Logs are delayed, incomplete, or overwritten Log evasion occurs when attackers:
- Disable logging services
- Delete or rotate logs aggressively
- Operate via trusted services with limited logs
- Use serverless or SaaS actions with weak telemetry

Key principle: You cannot detect what you cannot see unless you notice it's missing.

2. Common Blind Spot Categories (2026)

Blind Spot	Why It Exists
SaaS admin actions	Limited audit depth
OAuth token usage	Token reuse without login
Serverless execution	Ephemeral runtime
Cloud control plane	Logging disabled/misconfigured
Third-party integrations	No central telemetry
Endpoint gaps	EDR tampering

3. Typical SOC Alert Triggers (Indirect Signals)

Alert Source	Indicator	Why It Matters
SIEM	Sudden drop in log volume	Log tampering
Cloud Logs	Logging service disabled	Evasion
EDR	Agent stopped/uninstalled	Visibility loss
IAM	Actions without matching logs	Telemetry gap
UEBA	Behaviour change without events	Blind spot

4. Initial Triage – L1 SOC (Decision Gate)

Objective: Decide if this is operational noise or intentional evasion.

Triage Question	Yes	No	Explanation
Logs suddenly missing?	Escalate	Continue	Tampering
Logging disabled without ticket?	Escalate	Continue	Evasion
Activity inferred without events?	Escalate	Continue	Blind spot
EDR/agent unhealthy?	Escalate	Continue	Defense bypass
Occurs during other incidents?	Escalate	Continue	Cover-up

L1 Rule (2026): Missing logs during suspicious activity = incident until proven otherwise

5. Context Enrichment – L1 → L2

Context Dimension	What to Check	Why
Asset Type	Cloud, SaaS, endpoint	Visibility model
Log Retention	Days vs months	Forensics
Change History	Who disabled logging	Attribution
Parallel Telemetry	Network, billing, IAM	Corroboration
Timing Correlation	With auth / API abuse	Intent

6. Threat Classification

Category	Mapping
MITRE ATTCK	Defense Evasion
OWASP	Security Misconfiguration
Attack Type	Log Evasion / Telemetry Suppression
Incident Type	Detection Bypass

Important: Log evasion is often not the primary objective it enables others.

7. Severity Assessment (Visibility-Centric)

Factor	Low	Medium	High
Asset Criticality	Low	Medium	High
Blind Spot Size	Small	Moderate	Large
Duration	Minutes	Hours	Days
Concurrent Threats	None	Possible	Confirmed

Severity Logic: Asset Criticality × Blind Spot Duration × Concurrent Threat

8. Containment – L2 SOC (Restore Visibility First)

Action	Owner	Reason
Re-enable logging immediately	Platform / Cloud	Restore sight
Isolate affected assets	SOC	Stop abuse
Block suspicious identities	IAM	Kill access
Lock logging configuration	Cloud Sec	Prevent repeat
Snapshot remaining logs	SOC	Evidence

Critical Rule: Containment starts by turning the lights back on.

G. Evidence Preservation (Creative Forensics)

Evidence	Source	Purpose
Billing / usage logs	Cloud	Activity inference
Network flow logs	NDR	Behaviour
IAM audit trails	IDP	Actor
Backup logs	Platform	Tamper proof
External SaaS logs	Vendor	Gaps coverage

Rule: When primary logs are gone, pivot to secondary evidence.

10. Eradication – L2 → L3

Step	Purpose
Remove attacker access	Stop evasion
Harden logging configs	Prevent disablement
Enforce immutable logs	Tamper resistance
Add log-health alerts	Early warning

11. Recovery & Monitoring

Step	Validation
Full telemetry restored	SOC
Gaps documented	Security

Step	Validation
Monitoring window	30–90 days
No silent failures	SIEM

12. Post-Incident Review (SOC Maturity)

Area	Key Question
Root Cause	Misconfig or attacker?
Detection	Blind spot noticed early?
Coverage	What wasn't logged?
Retention	Sufficient for IR?
Improvement	Logging-by-design?

13. Management-Ready Summary

Item	Example
Incident	Log evasion detected
Impact	Partial visibility loss
Detection	Log-health monitoring
Containment	Visibility restored
Preventive Action	Immutable logging